

Huawei Cloud Security Hardening & Defense Lab

Technical Report: Architecture, Controls, and Security Engineering Rationale
August 2026

Abstract

This report documents the design and implementation of a hardened Huawei Cloud environment built as a security engineering portfolio project. It covers the technologies used, the network and identity architecture, the specific controls configured in each domain (identity, networking, security groups, perimeter firewall, object storage, logging, monitoring, and backup), the reasoning behind each control, a formal risk assessment, and the outcome of a final security validation pass. The project originates from the Huawei ICT Academy Cloud Security curriculum and extends it into an independently designed, documented, and reviewed cloud hardening exercise.

Revision Note

This revision adds the security engineering layer that sits around the controls described in the first version of this report: a formal threat model, a security control matrix, deployment flow renumbered to match the repository's nine implementation modules, test level validation evidence, a residual risk register, an incident response playbook explicitly marked as untested, architecture decision records, and a security best practice mapping.

A second, more important correction is made in this revision: an earlier draft used completed tense language in places ("the environment was confirmed to meet baseline production requirements," "a test restore was performed") that implied live testing had occurred against a real Huawei Cloud account. No live Huawei Cloud environment has been deployed at the time of this report. That language has been corrected throughout, most visibly in Sections 19 through 21.

How to read Sections 4 through 12. These sections describe the environment's designed configuration, what would be set up and how, using direct, present tense language for readability ("Cloud Trace Service is enabled account wide" reads more naturally than "the design specifies that Cloud Trace Service would be enabled account wide" repeated a dozen times). This phrasing describes the specification, not a live, verified state. The actual execution status of every control is tracked separately and explicitly in Section 19 (Security Validation) and Section 15 (Risk Assessment), where the language is deliberately Designed / pending deployment rather than confirmed / passed, because that is actually true at this stage.

Introduction

Cloud security coursework typically ends once a lab exercise is marked complete. This project starts from that point and treats the environment as a single connected system that needs securing end to end, rather than a set of isolated exercises to check off individually.

The guiding question behind this work was not how do I complete this lab, but rather how would a cloud security engineer actually secure a newly provisioned enterprise cloud environment before it goes into production. That framing shaped every decision documented in this report: which services to configure, in what order, and why each configuration choice matters beyond simply satisfying a checklist item.

1.1 Scope

The environment covers eight Huawei Cloud service domains: Identity and Access Management (IAM), Virtual Private Cloud (VPC) networking, Security Groups, Cloud Firewall, Object Storage Service (OBS), Cloud Trace Service (CTS) for logging, Cloud Eye for monitoring, and Cloud Backup for recovery. Each domain is treated as a layer in a defense in depth model rather than a standalone feature.

1.2 Relationship with the Huawei ICT Academy curriculum

The Huawei ICT Academy Cloud Security curriculum supplied the foundational service concepts referenced throughout this report. Everything beyond that, the architecture decisions, the specific hardening checklist, the risk table, the incident response notes, and the security review, was designed and written independently as an extension of that foundation.

Technologies Used

Service	Role in this project
Identity and Access Management (IAM)	Group based least privilege access, MFA enforcement, password policy
Virtual Private Cloud (VPC)	Network segmentation into public and private subnets
Elastic Cloud Server (ECS)	Compute instances hosting the application workload in the private subnet
Object Storage Service (OBS)	Encrypted, versioned, private by default data storage
Security Groups	Instance level stateful traffic filtering, scoped per tier
Cloud Firewall	Boundary level allow/deny traffic filtering
Cloud Trace Service (CTS)	Account wide administrative and API action logging
Cloud Eye	Resource monitoring and threshold-based alerting
Cloud Backup	Scheduled snapshots and documented recovery procedure (restore not yet executed)

System Architecture

1.3 Network Topology

The environment uses a single VPC divided into a public subnet, which holds only a bastion host, and a private subnet, which holds the ECS instances running the application. Cloud Firewall sits at the network boundary and filters traffic before it reaches either subnet.

1.4 Traffic Flow

- External traffic reaches Cloud Firewall first. Traffic not matching the allow list is dropped before it reaches any subnet.
- Traffic destined for the bastion host is checked a second time at the security group level, restricted to a defined set of administrative source IP ranges.
- Administrators reach the private subnet only through the bastion, over the internal network. There is no direct path from the public internet to an ECS instance.
- Traffic between instances within the private subnet is filtered by security groups scoped to the specific ports each tier requires.

Security Insight: Network segmentation does not prevent a breach by itself. It forces an attacker through additional checkpoints, each of which is an opportunity for logging and monitoring to detect what is happening before it escalates.

1.5 Before / After Security Posture

Threat Model

Before any control is described, every asset in this environment was mapped to a realistic threat and its attack surface, following the chain Asset → Threat → Attack Surface → Existing Control. This is distinct from the risk assessment in Section 15: the threat model identifies what could go wrong and where; the risk assessment rates how likely and how damaging each identified threat is.

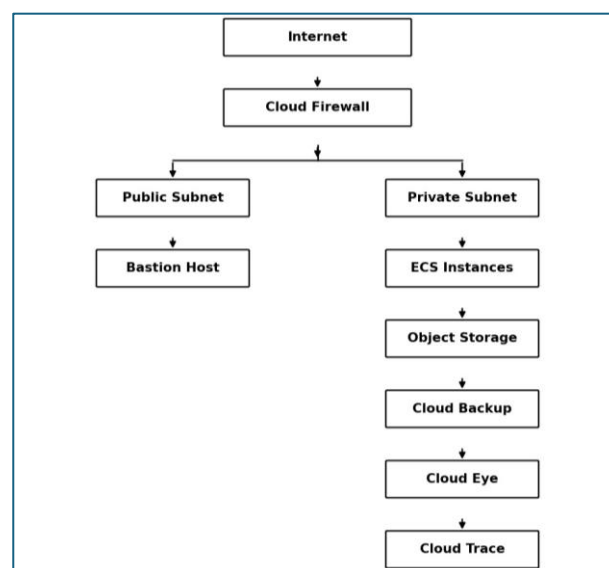


Figure 1: Network architecture: traffic flow from the internet through Cloud Firewall into the public and private subnets.

Asset	Threat	Attack Surface	Existing Control
IAM accounts	Credential compromise	Console / API	MFA + least privilege, strong password policy
Bastion host	Brute force	SSH	IP restriction, security groups
ECS instances	Unauthorized access	Network	Private subnet + security groups, bastion-only access
Object Storage	Data exposure	Storage API	Private bucket, encryption, versioning, expiring signed URLs
Cloud configuration	Malicious change	Management APIs	Cloud Trace Service (CTS) logging, IAM access controls
Infrastructure	Resource compromise	Runtime	Cloud Eye monitoring, security groups, cloud firewall, hardening baseline
Backups / snapshots	Data loss	Backup service	Scheduled snapshots, cloud backup, documented restore procedure
Network boundary	External scanning	Internet-facing edge	Cloud Firewall allow/deny lists, network segmentation, default-deny security groups

Cloud configuration itself is treated as an asset in this model because a malicious or accidental change to a security group, firewall rule, or IAM policy can silently undo every other control on this list, which is why account wide audit logging is treated as a control against configuration.

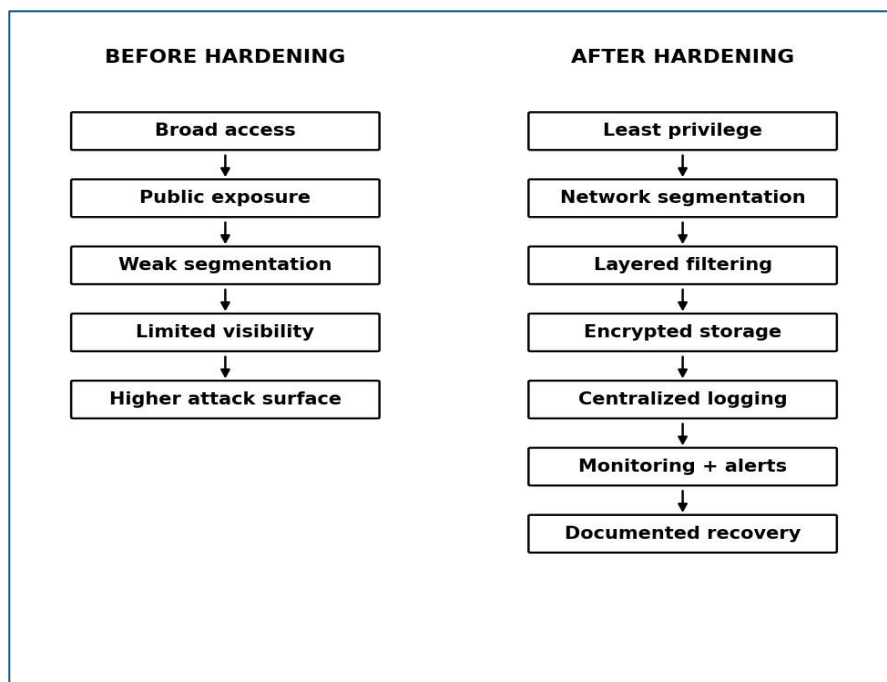


Figure 2: Security posture before and after applying the controls described in this report. Layer threats specifically, and not only as a general audit convenience.

Identity and Access Management

Access is assigned through groups (developers, operators, auditors) rather than to individual accounts, with policies attached at the group level. Multi factor authentication is required for all accounts with console access. The account password policy enforces a twelve-character minimum, complexity requirements, a ninety day rotation period, and a lockout after five consecutive failed login attempts.

The permission matrix for each group was reviewed against the group's actual function to confirm that no group holds more access than its role requires. This review step matters more than it might initially seem it is common for permissions to accumulate over time as exceptions are made, and a periodic review is what catches that drift.

Security Insight: Identity is the layer everything else depends on. A well configured firewall rule provides limited protection if an over permissioned account can simply reconfigure it.

Network Security

The VPC's CIDR range is split between the public and private subnets, with route tables configured so the private subnet has no direct route to the Internet Gateway. NAT is configured so private subnet instances can reach the internet for software updates without being reachable from it.

Common Misconfiguration: A private subnet route table left with an unintended route to the Internet Gateway is a common setup mistake, often introduced during initial configuration and not noticed until a resource is exposed that should not be. Route tables should be checked directly rather than assumed correct.

Security Groups

Security groups are configured on a default denied basis, with three tiers:

- Bastion: inbound SSH restricted to a defined set of administrative source IPs; no other inbound rules.
- Application tier: inbound limited to the bastion's security group (for SSH) and the load balancer tier (for the application port); outbound limited to the database port on the database tier.
- Database tier: inbound limited to the application tier's security group on the database port only; no outbound rules configured.

Common Misconfiguration: Leaving SSH (port 22) or a database port open to 0.0.0.0/0 is one of the most common findings in cloud security reviews and one of the most targeted patterns by automated internet scanning. Database security groups in particular should only ever accept traffic from the specific application tier that needs it.

Cloud Firewall

Cloud Firewall provides a second, boundary level filtering layer on top of the security groups described above. It is designed with an explicit allow list matching expected traffic patterns and a deny list covering known bad ranges. Both lists have a documented test procedure (T 005 in the test register) to confirm they behave as specified once deployed; that test has not yet been executed against a live account.

Security Control Matrix

Where the threat model identifies what could go wrong, this matrix maps every designed control back to the security objective it serves and where the evidence for it would live once captured. No live account exists yet, so the "Evidence" column below names the evidence artifact's intended location, not evidence that currently exists.

Domain	Control	Security Objective	Evidence (once captured)
IAM	MFA	Account protection	Screenshot, validation IAM-01
IAM	Group-based permissions	Least privilege	Permission matrix
VPC	Private subnet	Reduce exposure	Route table review
Security Groups	Default deny	Restrict lateral movement	Rule set
Cloud Firewall	Allow/deny rules	Perimeter filtering	Firewall rules
Object Storage	Encryption	Data protection	Bucket configuration

Domain	Control	Security Objective	Evidence (once captured)
CTS	Audit logging	Accountability	Log evidence
Cloud Eye	Alerts	Detection	Monitoring dashboard
Cloud Backup	Test restore	Recovery	Restore evidence

A row in this table is only considered complete once it has a concrete, real evidence reference behind it, not merely a description of intended configuration, and not merely a named location where evidence will eventually go.

Object Storage Security

Object Storage Service buckets are configured privately by default, with server side encryption and versioning enabled. Versioning protects against accidental deletion or overwrites by preserving prior object states. Where external sharing is unavoidable, access is granted through signed URLs with a defined expiry rather than making a bucket public.

Logging

Cloud Trace Service is enabled account wide and configured to capture IAM changes, VPC and security group changes, Cloud Firewall rule changes, OBS actions, and ECS actions. Logs are routed to a storage destination that is not writable or deletable by the accounts whose actions are being logged, which preserves the integrity of the audit trail even if an account is later compromised.

Monitoring

Cloud Eye is enabled on all ECS instances, tracking CPU utilization, memory utilization, disk utilization, and network traffic. Alert thresholds were set from an initial estimate of expected baseline usage (85% CPU, 90% memory, 85% disk, sustained over multiple evaluation periods) and are flagged for returning once real production traffic data is available.

Backup and Recovery

ECS instance snapshots are designed to be scheduled on a recurring basis through Cloud Backup. A restore procedure has been designed and documented step by step; live restoration testing remains pending deployment in Huawei Cloud, since no ECS instance or snapshot exists yet to restore from.

Security Engineer's Notes: The value of an audit trail is not fully appreciated until the first time something looks wrong and the question "who changed this, and when" needs an answer quickly. That is the moment a properly configured logging setup pays for itself.

Incident Response Playbook

Status: documented, tabletop exercise pending. Two scenarios are documented against this environment's actual logging and monitoring setup: a compromised IAM account and a compromised ECS instance. Neither has been walked through as a tabletop exercise, and that limitation is stated directly rather than implied, since claiming a tested process without testing it would misrepresent the state of the project.

- **Scenario 01, Compromised IAM account:** detect → review CTS logs → identify suspicious actions → disable account → rotate credentials → review permission scope → investigate affected resources → restore secure state → document incident.
- **Scenario 02, Compromised ECS instance:** detect → isolate instance → snapshot before remediation → investigate logs and running processes → rebuild from known good image → rotate affected credentials → document incident.

A tabletop exercise would mean walking through one of these scenarios with the people who would actually respond, using real console access, and timing each step. That has not happened yet; until it does, this playbook is a documented starting point rather than a proven process.

Risk Assessment

No live Huawei Cloud environment has been deployed yet. Every "Residual" value below is a projected residual risk after implementing the proposed controls, not a measured result from a live environment, it becomes a validated measurement only once the controls are deployed and the corresponding tests in the register are actually run.

Risk	Impact	Likelihood	Designed Mitigation	Projected Residual Risk
Weak or shared IAM credentials	High	Medium	MFA enforced, group-based least privilege, strong password policy	Low
Security group open on an admin port	High	High	Default-deny groups, SSH restricted to bastion	Low
No audit trail for config changes	Medium	High	Cloud Trace Service enabled account-wide	Low
Publicly accessible storage bucket	High	Medium	Private-by-default buckets, signed URLs	Low
Undetected resource compromise	High	Medium	Cloud Eye monitoring with alert thresholds	Medium
Untested backup/recovery process	Medium	Medium	Scheduled snapshots planned, restore procedure documented (<i>execution pending</i>)	Medium
Lateral movement between instances	High	Medium	Public/private subnet split, tiered security groups	Low
Unpatched instance software	Medium	Medium	Patch schedule in hardening checklist	Medium
Alert fatigue from poor thresholds	Low	Medium	Baseline thresholds, flagged for review	Medium

Three risks are projected at medium residual severity: monitoring threshold accuracy, backup/recovery robustness under real conditions, and patch cadence over time. Each depends on information (real production traffic, a live incident, or an extended time horizon) that cannot be evaluated without a live deployment, and each is tracked explicitly as follow up work. Even the risks projected at "Low" residual severity are projections based on the design working as intended, not confirmed observations, none of the ratings in this table have been validated against a live account.

Residual Risk Register

A risk rating alone does not communicate why a risk stays at Medium after mitigation, or what would actually close it. The register below carries that detail for each of the three medium residual items identified above.

Item	Why it remains	Closes when
RR 01: Monitoring threshold accuracy	Thresholds set from an initial estimate, not observed production traffic	Retuned after a reasonable observation period against real traffic
RR 02: Backup/recovery robustness	A single successful restore confirms the process under one condition, not under incident pressure	A second restore tested under simulated incident conditions
RR 03: Patch cadence overtime	A documented schedule only reduces risk if followed consistently, which a one time pass cannot confirm	A full patch cycle completed with evidence of compliance

Risks already rated Low residual (IAM credential compromise, open security groups, missing audit trail, public storage exposure, lateral movement) are not repeated in this register, since it exists specifically to track what is left over after mitigation, not to restate the full risk table.

Architecture Decision Records

Five architecture decision records (ADRs) capture the reasoning behind the core design choices in this project, including the alternatives considered and why each was not used. They are summarized here; full detail lives in the repository under docs/decisions/.

- **ADR 001, Public/private subnet split:** chosen over a flat network to remove the internet as a direct attack surface against the workload.
- **ADR 002, Bastion host instead of direct SSH to application servers:** concentrates administrative risk onto one hardened, monitored entry point rather than distributing it across every instance.
- **ADR 003, Default deny security groups:** chosen over default allow with a later cleanup pass, since a planned cleanup with no hard deadline is easy to deprioritize.

- **ADR 004, Private object storage by default:** removes the most common cloud storage misconfiguration category by requiring an explicit, documented reason for any public access rather than relying on manual review.
- **ADR 005, Account wide audit logging:** chosen over selective logging on” high risk” services only, since that judgment call can be wrong and the cost of full coverage is low relative to its investigative value.

Security Best Practice Mapping

The controls in this report are grounded in recognized general security practice. This is presented as best practice mapping, not a certification or formal compliance claim.

Project Control	Reference
Least privilege (IAM groups, MFA)	CIS Controls / general IAM best practices
Network segmentation	Cloud security architecture best practices
Default deny security groups	CIS Cloud Security Benchmarks (general reference)
Account wide audit logging	Audit and security logging principles
Encryption at rest	Cloud data protection best practices
Threshold based monitoring	Security monitoring and detection principles
Tested backup and recovery	Business continuity / disaster recovery best practices

Security Validation

No live Huawei Cloud environment has been deployed at the time of this report.

A design review pass was run against the full hardening checklist after all nine implementation modules were specified: IAM, VPC Network Security, Security Groups, Cloud Firewall, Object Storage Security, Logging, Monitoring, Backup & Recovery, and Infrastructure Hardening, with Risk Assessment, Security Validation, and Incident Response run as a review layer across all nine rather than as separate modules themselves. The architecture was reviewed against the defined security baseline across identity, network segmentation, security group scope, firewall configuration, storage security, and logging coverage. Live validation of every item below remains pending deployment in Huawei Cloud. Two items are additionally flagged as incomplete even at the design level: monitoring thresholds are based on an initial estimate rather than observed production traffic, and the incident response playbook has no tabletop exercise scheduled.

Design Review Dashboard

Domain	Status
IAM	Designed
Network Segmentation	Designed

Security Groups	Designed
Cloud Firewall	Designed
Storage Security	Designed
Logging	Designed
Monitoring	Designed (thresholds unvalidated)
Backup & Recovery	Designed (not yet executed)
Incident Response	Designed only (no tabletop scheduled)

Table 7: Design review status by domain.

” DESIGNED” means the control has a complete specification and, where applicable, a written test procedure, not that it has been configured or verified against a live account. This report previously used” PASS” and” PARTIAL” language here, which implied live testing had occurred; that language has been corrected, since no live environment exists yet to test against. A locally runnable simulation of several of the underlying test procedures exists (Section 22) and produces genuine output, but that output is explicitly a simulation, not live Huawei Cloud evidence, and is not reflected in this dashboard.

Findings Summary

Area	Status	Notes
IAM least privilege	Designed	Permission matrix reviewed against role function; not yet verified live
MFA enforcement	Designed	Specified as required on all console accounts; not yet configured
Network segmentation	Designed	Public/private split specified; no VPC provisioned yet
Security group scope	Designed	No admin port intended open to 0.0.0.0/0; rules not yet created
Storage encryption	Designed	Server side encryption and versioning specified; no bucket created yet
Logging coverage	Designed	CTS configuration specified; not yet enabled
Monitoring thresholds	Designed	Estimated baseline, no traffic data, not yet configured live
Incident response	Designed only	Documented; tabletop exercise not scheduled

Design Baseline Score

This scores the completeness of the design, not a verified live posture. No Huawei Cloud account has been deployed, so this number reflects how fully specified each domain is, not whether the control has been proven to work. It should be recalculated as a Validated Security Posture Score, using real test outcomes only, once deployment and testing actually happen.

Domain	Max	Earned	Basis
IAM	15	15	Design fully specified with a written permission matrix and test procedure
Network	15	15	Subnet plan and route review fully specified with a test procedure
Security Groups	15	15	Full tiered rule matrix specified with test procedures (T-001, T-004)
Firewall	10	10	Allow/deny policy fully specified with a test procedure (T-005)
Storage	10	10	Bucket security settings fully specified with a test procedure (T-007)
Logging	10	10	CTS coverage fully specified with a test procedure (T-006)
Monitoring	10	7	Specified, but thresholds are an unvalidated initial estimate (three points deducted)
Domain	Max	Earned	Basis
Backup	5	5	Restore procedure fully specified step by step, even though not yet executed
Incident Response	10	0	No tabletop exercise scheduled — no committed next step, unlike other domains
Total	100	87	

This is not a compliance certification and is not derived from any test in the register actually passing, since none have been executed. Full methodology is documented in docs/design baseline score.md.

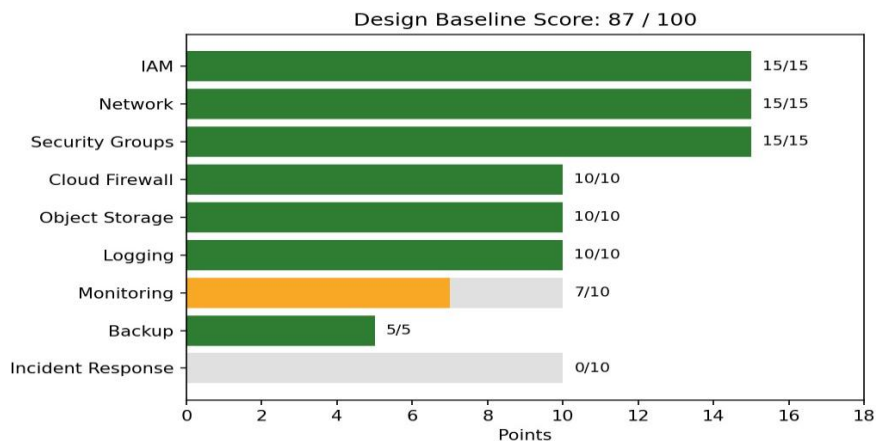


Figure 3: Design Baseline Score by domain (87/100 total). Green bars indicate full points earned; orange indicates partial credit; the unfilled portion of a bar shows points not yet earned.

Once a live account exists and the tests in the register are actually executed, this score should be retired in favor of a Validated Security Posture Score computed only from real results, moving from 87/100 (Design Baseline) to a real score (Validated Security Posture), the two should never be conflated, since one measures plan completeness and the other measures observed behavior.

Local Lab: A Runnable Simulation

To keep the project demonstrable before live Huawei Cloud access is available, a small local application (local lab/) implements a rule based local security validation simulator, based on this project's designed Huawei Cloud security architecture, not a Huawei Cloud emulator, and not a reproduction of any real Huawei Cloud API or service. It models the core security logic described in this report: an IP allow list check for the bastion, a firewall denylist check, tiered security group reachability, and a CPU threshold alert check, alongside four generalized rule testers (network, firewall, security group, monitoring) that accept arbitrary input rather than replaying a fixed scenario. It runs with python app.py and is viewed at

<http://localhost:5000>, in the same way a locally run web application would be. Every result it produces comes from real code evaluating real input, so changing a source IP or a CPU percentage changes the outcome. The interface labels every result LOCAL SIMULATION throughout, and its output is never written back into the design review dashboard or the test register, since a local rule model is not evidence about a live Huawei Cloud account.

This repository also contains a separate static dashboard (dashboard/); the two are deliberately not the same thing. The local lab is interactive; it computes a fresh result from whatever input is given. The dashboard is presentation only; it displays a hand maintained snapshot of the documents already described in this report and has no logic of its own.

Project Layers and Execution Roadmap

This project is best understood as three layers rather than one flat set of files. Layer 1, the Cloud Security Architecture is the formal design: IAM through VPC, security groups, Cloud Firewall, object storage, logging, monitoring, and backup, with the public/private subnet split described in Section 3. Layer 2, the Security Engineering Case Study, is the professional layer wrapped around that architecture, the threat model, control matrix, risk assessment, residual risk register, ADRs, best practice mapping, and validation framework covered in Sections 4, 9, 15–18, and 19–20. Layer 3, the Runnable Local Lab, is Section 22. Layers 1 and 2 are complete as designs; Layer 3 is complete and actually runs; none of Layer 1 has been deployed to a live account yet.

From here, five stages connect this design to a fully validated environment:

- I. Local verification, run local lab/ and confirm every test behaves as documented. Available immediately, no Huawei Cloud account required.
- II. Improve the local lab, the generalized rule testers described in Section 22 extend this from ten fixed scenarios into a small standalone rule testing tool.
- III. Deploy to Huawei Cloud, build the architecture in Section 3 in a real account, turning Layer 1 from a design into an environment.
- IV. Connect real evidence, execute each test in the register against the live account, capture the result, and update the corresponding evidence record and control matrix row from "Designed" to a real PASS, FAIL, or PARTIAL.
- V. Optional live dashboard integration, only after Stage 4 is substantially complete, connect dashboard/ to real Huawei Cloud data via the SDK backed approach outlined in the repository's dashboard/backend/README.md.

None of these stages require restructuring the repository. Every placeholder already in place (Designed | pending deployment, the Design Baseline Score, the projected residual risk ratings) is designed to be updated in place as real results replace them, described fully in docs/execution roadmap.md.

Conclusion and Future Work

The design documented in this report specifies a complete baseline across identity, network segmentation, security groups, perimeter firewall, storage security, audit logging, monitoring, and backup and recovery. None of it has been deployed to a live Huawei Cloud account yet, and no finding

in this report should be read as a verified live result. The architecture was reviewed against the defined security baseline; live validation remains pending deployment in Huawei Cloud.

Planned future work includes deploying this design to an actual Huawei Cloud account and executing every test in the register against it, replacing each "Designed" status with a real observed result; migrating the manual configuration to infrastructure as code (Terraform or Huawei Cloud's native tooling); connecting Cloud Eye alerts to a real time notification channel; and scheduling the incident response tabletop exercise.